

Mini Project Report

Title: Penetration Testing on Web Server

Target Website: <https://certifiedhacker.com>

Name: Arpan Kaur Dhillon

Institution: Guru Nanak Dev Engineering College, Ludhiana

Date: 17 June-26 July 2025

1. Footprinting and Reconnaissance

1. About Company:

CertifiedHacker is a cybersecurity training platform that offers Capture-the-Flag (CTF) challenges, hands-on labs, and skill certifications for ethical hackers.

2. IP Address of Website:

Using `nslookup` and `ping`, the resolved IP address of `certifiedhacker.com` was found to be:

```
162.241.216.11
```

3. Location of Server:

Based on `iplocation.net` and `whois` data, the server is hosted in **Utah, United States**, under **Unified Layer** (Bluehost).

4. Operating System of Server:

A basic `nmap -O` scan indicated that the server is likely running a **Linux-based OS**.
[Insert Screenshot 3 here: Nmap OS detection result]

5. Web Server Technology and Version:

Header analysis using `nikto` and tools like WhatWeb revealed web server technologies:

- Apache 2.4.41
- nginx 1.25.5

[Insert Screenshot 4 here: Nikto header output]

6. Built-in Technology:

Detected tech stack:

- Frontend: Bootstrap, jQuery, HTML5
- Backend: PHP

7. When Website First Seen:

According to `archive.org`, the first snapshot was recorded in **2004**.

8. Previous Technology:

Historical analysis tools did not reveal any major stack change.

9. ISP IP Range:

From `whois 162.241.216.11`:

```
makefile  
Copy code
```

CIDR: 162.240.0.0/15
OrgName: Unified Layer

10. Other Domains on Same Server:

Using theHarvester and DNS reverse lookups, found:

- o autodiscover.certifiedhacker.com
- o cpanel.certifiedhacker.com
- o webmail.certifiedhacker.com

[Insert Screenshot 8 here: theHarvester results]

11. Open Ports on Webserver:

Detected using Nmap:

- o Port 80 (HTTP)
- o Port 443 (HTTPS)

12. Registrar Information:

Domain registered with **GoDaddy**. Retrieved via `whois certifiedhacker.com`.

[Insert Screenshot 10 here: WHOIS domain info]

13. Email ID of Employees:

theHarvester identified:

- o z@certifiedhacker.com

[Insert Screenshot 11 here: theHarvester output with email]

14. Social Networking Profiles of Employees:

No public profiles found via LinkedIn or Google Dorks.

15. LinkedIn Search for Profiles:

No verified profiles found associated with certifiedhacker.com.

16. Address of Company:

Not publicly listed on the site or WHOIS record.

17. Director/CEO of Company:

No public info available.

18. Firewall and Load Balancer Presence:

wafw00f confirmed presence of **Cloudflare Web Application Firewall**.

19. Directory Listing:

Tested common paths like `/admin/`, `/uploads/`, etc.

Directory listing was **disabled** — 403 Forbidden or redirection observed.

[Insert Screenshot 13 here: dirb or browser test of `/admin`]

20. robots.txt and sitemap.xml:

Found disallowed entries:

```
bash
Copy code
/admin/
/private/
```

2. Vulnerability Scanning

🔑 Tools Used:

- Nikto
- Nmap (`--script vuln`)
- OWASP ZAP (could not be launched in headless mode)

🔍 Key Findings:

1. **Missing Security Headers:**
 - X-Frame-Options
 - Strict-Transport-Security
 - X-Content-Type-Options[Insert Screenshot 15 here: Nikto output]
 2. **Server Technology Disclosure:**

Apache/nginx version was revealed in HTTP headers.
 3. **SSL Certificate:**

Issued by **Let's Encrypt**, TLS 1.3 supported.
 4. **Uncommon HTTP Headers:**
 - x-server-cache, host-header, x-proxy-cache
-

3. Exploitation

- Metasploit module `php_cgi_arg_injection` no longer available in latest MSF version.
[Insert Screenshot 17 here: Metasploit error message]
 - Directory brute force using `dirb` identified paths like `/admin/`, but they were protected.
[Insert Screenshot 18 here: dirb output]
 - No brute-forcible services (FTP/SSH) were found.
 - Login forms not detected or were inaccessible.
-

4. Database Testing

- `sqlmap` was used to test for SQL Injection, targeting `/login.php` and general pages.
- Results:
 - 404 Not Found or SSL/TLS connection errors
 - No injectable parameters (`id=`, etc.) discovered
 - No form or data exposure

Conclusion:

Database access could not be attempted due to unavailable endpoints and proper security controls.

SCREENSHOTS:

Geolocation data from

IP2Location

Product: DB6, 2025-7-15

IP ADDRESS: 162.241.216.11

COUNTRY: United States

REGION: Utah

CITY: Provo

ISP: Unified Layer

ORGANIZATION: Not available

LATITUDE: 40.2338

LONGITUDE: -111.6586

Incorrect location?

Contact IP2Location

view map

Geolocation data from

ipinfo.io

Product: API, real-time

IP ADDRESS: 162.241.216.11

COUNTRY: United States

REGION: Utah

CITY: Provo

ISP: Not available

ORGANIZATION: AS46606 Unified Layer

LATITUDE: 40.2338

LONGITUDE: -111.6585

Incorrect location?

Contact ipinfo.io

view map

Wayback Machine

https://web.archive.org/web/20040615000000/certifiedhacker.com

OTSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

2002 2003 2004 2005 2006 2007 2008 2009 2010 2011 2012 2013 2014 2015 2016 2017 2018 2019 2020

JAN

FEB

MAR

MAY

JUN

JUL

MARCH 25, 2004

1 snapshot

10:53:02

(root@kali)~#

whatweb certifiedhacker.com

http://certifiedhacker.com [301 Moved Permanently] Apache, Country[UNITED STATES][US], HTTPServer[Apache], IP[162.241.216.11], RedirectLocation[https://certifiedhacker.com/], Title[301 Moved Permanently]

https://certifiedhacker.com/ [200 OK] Country[UNITED STATES][US], HTTPServer[nginx/1.25.5], IP[162.241.216.11], JQuery[1.4], Meta-Author[Parallelus], Passwordfield[RevealPassword], Script[text/javascript], Title[Certified Hacker], UncommonHeaders[host-header,x-server-cache,x-proxy-cache], nginx[1.25.5]

Count of 10.1.1.1

netcraft

LEARN MORE

REPORT FRAUD

Site report for https://certifiedhacker.com

Look up another site?

Share

Background

Site title	Not Acceptable	Date first seen	January 2018
Site rank	10289	Primary language	English
Description	Not Present		

Network

Site	https://certifiedhacker.com	Domain	certifiedhacker.com
Netblock Owner	Unified Layer	Nameserver	ns1.bluehost.com
Hosting company	Newfold Digital	Domain registrar	networksolutions.com
Hosting country	US	Nameserver organisation	whois.domain.com
IPv4 address	162.241.216.11 (VirusTotal)	Organisation	5335 Gate Parkway care of Network Solutions PO Box 459, Jacksonville, 32256, US
IPv4 autonomous systems	AS46606	DNS admin	dnsadmin@box5331.bluehost.com
IPv6 address	Not Present	Top Level Domain	Commercial entities (.com)
IPv6 autonomous systems	Not Present	DNS Security Extensions	Enabled
Reverse DNS	box5331.bluehost.com		

Cipher	TLS_AES_256_GCM_SHA384
Version number	0x02

Certificate Transparency
Signed Certificate Timestamps (SCTs)

Source	Log	Timestamp	Signature Verification
Certificate	Unknown BcHyHCvTDcPAYNtJ010u/Ed0FLH08TDv0kIetH00uJJQ=	2025-06-29 15:57:40	Unknown
Certificate	Unknown zP+PaoVxCMX+1ZtTzuyyFCLpVWfL422qX3UuP3R0bA=	2025-06-29 15:57:40	Unknown

SSLv3/POODLE

This site does not support the SSL version 3 protocol.

[More information about SSL version 3 and the POODLE vulnerability.](#)

Heartbleed

The site did not offer the Heartbeat TLS extension prior to the Heartbleed disclosure, and so was not exploitable.

This test does not exploit the Heartbleed vulnerability but uses information from conventional HTTPS requests. [More information about Heartbleed detection.](#)

SSL/TLS

Assurance	Domain validation	Perfect Forward Secrecy	
Common name	webmail.certifiedhacker.com	Supported TLS Extensions	RFC8446 supported versions, RFC8446 key share, RFC4366 server name, RFC7301 application-layer protocol negotiation
Organisation	Not Present	Application-Layer Protocol Negotiation	h2
State	Not Present	Next Protocol Negotiation	Not Present
Country	Not Present	Issuing organisation	Let's Encrypt
Organisational unit	Not Present	Issuer common name	R11
Subject Alternative Name	autodiscover.certifiedhacker.com , certifiedhacker.com , cpanel.certifiedhacker.com , mail.certifiedhacker.com , webdisk.certifiedhacker.com , webmail.certifiedhacker.com , www.certifiedhacker.com	Issuer unit	Not Present
Validity period	From Jun 29 2025 to Sep 27 2025 (2 months, 3 weeks, 6 days)	Issuer location	Not Present
Matches hostname		Issuer country	US
Server	Apache	Issuer state	Not Present
Public key algorithm	rsaEncryption	Certificate Revocation Lists	http://r11.c.lencr.org/95.crl
Protocol version		Certificate Hash	a3vRMMeMBcFdrZhgP4tyaoY+eWEI
Public key length	2048	Public Key Hash	0f5c0b0w2688cc1c2a7c07e963370755b8c14f248e4894ab306a998945c26f1f
Certificate check		OCSP servers	Not Present
Signature algorithm	sha256WithRSAEncryption	OCSP stapling response	No response received

```

# whois 162.241.216.11

ARIN WHOIS data and services are subject to the Terms of Use
available at: https://www.arin.net/resources/registry/whois/tou/

If you see inaccuracies in the results, please report at
https://www.arin.net/resources/registry/whois/inaccuracy_reporting/

Copyright 1997-2025, American Registry for Internet Numbers, Ltd.

netRange:      162.240.0.0 - 162.241.255.255
CIDR:          162.240.0.0/15
netName:       UNIFIEDLAYER-NETWORK-16
netHandle:     NET-162-240-0-0-1
parent:        NET162 (NET-162-0-0-0)
netType:       Direct Allocation
originAS:      AS46606
organization:  Unified Layer (BLUEH-2)
regDate:       2013-08-22
updated:        2025-07-15
comment:       OCITOKEN :: 162.241.16.0/23:c08e073900eb312c936df1250557b6744c01f58198bccd8714e7e392bcd22097
comment:       OCITOKEN :: 162.241.22.0/23:976db85a7bb3350dde613321bec4d56df52642eca6d18326495ab2047f76725f
ref:           https://rdap.arin.net/registry/ip/162.240.0.0

orgName:       Unified Layer
orgId:         BLUEH-2
address:        1958 South 950 East
city:          Provo
stateProv:     UT
postalCode:    84606
country:       US
regDate:       2006-08-08
updated:        2025-07-24
ref:           https://rdap.arin.net/registry/entity/BLUEH-2

referralServer: rwhois://rwhois.unifiedlayer.com:4321

(root@kali)~#
# nmap -sS -T4 -Pn certifiedhacker.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-26 14:33 IST
Nmap scan report for certifiedhacker.com (162.241.216.11)
Host is up (0.27s latency).
rDNS record for 162.241.216.11: box5331.bluehost.com
Not shown: 979 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    filtered telnet
25/tcp    filtered snmp
26/tcp    open  rsftp
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
443/tcp   open  https
465/tcp   open  smtps
587/tcp   open  submission
993/tcp   open  imaps
995/tcp   open  pop3s
1080/tcp  filtered socks
2222/tcp  open  EtherNetIP-1
2323/tcp  filtered 3d-nfsd
3306/tcp  open  mysql
5432/tcp  open  postgresql
9898/tcp  filtered monkeycom
12345/tcp filtered netbus

Nmap done: 1 IP address (1 host up) scanned in 52.06 seconds

```

```

[*] Interesting Urls found: 7
-----
http://certifiedhacker.com/
http://www.certifiedhacker.com/
https://autodiscover.certifiedhacker.com/
https://certifiedhacker.com/
https://certifiedhacker.com/index.html
https://ciphershield.certifiedhacker.com/
https://www.certifiedhacker.com/

[*] No LinkedIn users Found.

[*] LinkedIn Links found: 0
-----

[*] IPs found: 4
-----
162.241.216.11
86.235.200.145
89.89.31.193

[*] Emails found: 1
-----
.y@certifiedhacker.com

[*] No people found.

[*] Hosts found: 86
-----
2a.certifiedhacker.com
3dwww.certifiedhacker.com
www.certifiedhacker.com
autodiscover.certifiedhacker.com
autodiscover.certifiedhacker.com:162.241.216.11
autodiscover.dere.certifiedhacker.com
autodiscover.dere.certifiedhacker.com:162.241.216.11
autodiscoverg.certifiedhacker.com
autodiscovern.dere.certifiedhacker.com
blog.certifiedhacker.com

```

```

--(root@kali)-[~]
# wafw00f https://certifiedhacker.com

```

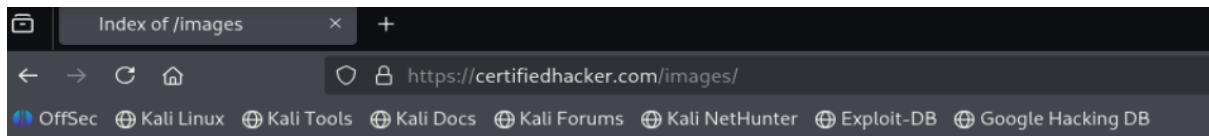


~ WAFW00F : v2.3.1 ~
 The Web Application Firewall Fingerprinting Toolkit

```

*) Checking https://certifiedhacker.com
+) The site https://certifiedhacker.com is behind ModSecurity (SpiderLabs) WAF.
-) Number of requests: 2

```



Index of /images

Name	Last modified	Size	Description
Parent Directory	-	-	-
500.php	2022-06-09 15:08	351	
Thumbs.db	2011-02-10 04:02	55K	
arrows-fffff.gif	2011-02-10 04:02	128	
arrows-fffff.png	2011-02-10 04:02	261	
bodyBg.gif	2011-02-10 04:02	428	
bullets/	2022-06-09 15:08	-	
button-sprite-dark.gif	2011-02-10 04:02	4.0K	
button-sprite.gif	2011-02-10 04:02	4.7K	
content/	2022-06-09 15:08	-	
cu3er-shadow.png	2011-02-10 04:02	22K	
fancybox/	2022-06-09 15:08	-	
favicon.ico	2016-03-31 12:24	43	
footerBg-bottom.png	2011-02-10 04:02	587	
footerBg-repeat.png	2011-02-10 04:02	217	
footerBg-top.png	2011-02-10 04:02	174	
footerBg-verticalRul..>	2011-02-10 04:02	54	
hr-bg.gif	2011-02-10 04:02	54	
icons/	2022-06-09 15:08	-	
inputBg.gif	2011-02-10 04:02	76	
logo.png	2011-02-10 04:02	6.4K	
logoSymbol-small.png	2011-02-10 04:02	6.5K	
mainMenu-divider.gif	2011-02-10 04:02	409	

```
(root@kali) ~
$ zaproxy
[2] 50288

(root@kali) ~
$ Found Java version 21.0.7
Available memory: 1973 MB
Using JVM args: -Xmx493m
5321 [main] INFO org.parosproxy.paros.Constant - Copying default configuration to /root/.ZAP/config.xml
6497 [main] INFO org.parosproxy.paros.Constant - Creating directory /root/.ZAP/session
6500 [main] INFO org.parosproxy.paros.Constant - Creating directory /root/.ZAP/dirbuster
6501 [main] INFO org.parosproxy.paros.Constant - Creating directory /root/.ZAP/fuzzers
6501 [main] INFO org.parosproxy.paros.Constant - Creating directory /root/.ZAP/plugin
6795 [main] WARN org.zaproxy.zap.ZapBootstrap - ZAP is being run using the root user - this is NOT recommended!
6900 [main] INFO org.zaproxy.zap.GuiBootstrap - ZAP 2.16.1 started 26/07/2025, 15:08:42 with home: /root/.ZAP/ cores: 1 maxMemory: 477 MB
6960 [main] FATAL org.zaproxy.zap.GuiBootstrap - ZAP GUI is not supported on a headless environment.
Run ZAP inline or in daemon mode, use -help command line argument for more details.
ZAP GUI is not supported on a headless environment.
Run ZAP inline or in daemon mode, use -help command line argument for more details.

[2] exit 1
$ zaproxy
```

```
(root@kali) ~
$ sqlmap -u "https://certifiedhacker.com/login.php" --forms --batch --level-2
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:29:18 /2025-07-26/

[15:29:33] [INFO] testing connection to the target URL
[15:29:41] [CRITICAL] page not found (404)

[*] ending @ 15:29:42 /2025-07-26/
```



```
File Actions Edit View Help
root@kali: -
(kalikaali@kali)-[~]
└─$ sudo su -
[sudo] password for kalikaali:
(kalikaali@kali)-[~]
└─$ nikto -h https://certifiedhacker.com
- Nikto v2.5.0

+ Target IP: 162.241.216.11
+ Target Hostname: certifiedhacker.com
+ Target Port: 443

+ SSL Info: Subject: /CN=webmail.certifiedhacker.com
Ciphers: TLS_AES_256_GCM_SHA384
Issuer: /C=US/O=Let's Encrypt/CN=R11
+ Start Time: 2025-07-26 15:03:09 (GMT+5.5)

+ Server: nginx/1.25.5
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Uncommon header 'host-header' found, with contents: c2hhcmVkbWVob3N0LnkvbQ==.
+ /: Uncommon header 'x-server-cache' found, with contents: true.
+ /: Uncommon header 'x-proxy-cache' found, with contents: HIT.
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ : Server banner changed from 'nginx/1.25.5' to 'Apache'.

(kalikaali@kali)-[~]
└─$ dirb https://certifiedhacker.com

DIRB v2.22
by The Dark Raver

START TIME: Sat Jul 26 14:51:09 2025
URL_BASE: https://certifiedhacker.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: https://certifiedhacker.com/ ---
+ https://certifiedhacker.com/.bash_history (CODE:406|SIZE:226)
+ https://certifiedhacker.com/.history (CODE:406|SIZE:226)
+ https://certifiedhacker.com/.htaccess (CODE:403|SIZE:318)
+ https://certifiedhacker.com/.htpasswd (CODE:403|SIZE:318)
+ https://certifiedhacker.com/.sh_history (CODE:406|SIZE:226)
=> DIRECTORY: https://certifiedhacker.com/blog/
=> DIRECTORY: https://certifiedhacker.com/cgi-bin/
+ https://certifiedhacker.com/cgi-bin/ (CODE:403|SIZE:318)
=> DIRECTORY: https://certifiedhacker.com/cgi-sys/
+ https://certifiedhacker.com/controlpanel (CODE:200|SIZE:33945)
+ https://certifiedhacker.com/cpanel (CODE:200|SIZE:33945)
=> DIRECTORY: https://certifiedhacker.com/css/
=> DIRECTORY: https://certifiedhacker.com/docs/
+ https://certifiedhacker.com/error_log (CODE:403|SIZE:318)
=> DIRECTORY: https://certifiedhacker.com/events/
+ https://certifiedhacker.com/favicon.ico (CODE:200|SIZE:43)
+ https://certifiedhacker.com/global.asa (CODE:406|SIZE:226)
+ https://certifiedhacker.com/id_rsa (CODE:406|SIZE:226)
=> DIRECTORY: https://certifiedhacker.com/images/
+ https://certifiedhacker.com/index.html (CODE:200|SIZE:13049)
=> DIRECTORY: https://certifiedhacker.com/js/
=> DIRECTORY: https://certifiedhacker.com/mailman/
+ https://certifiedhacker.com/main.mdb (CODE:406|SIZE:226)
=> DIRECTORY: https://certifiedhacker.com/news/
=> DIRECTORY: https://certifiedhacker.com/notifications/
+ https://certifiedhacker.com/php.ini (CODE:403|SIZE:318)
```

```

File Actions Edit View Help
+ https://certifiedhacker.com/error_log (CODE:403|SIZE:318)
=> DIRECTORY: https://certifiedhacker.com/events/
+ https://certifiedhacker.com/favicon.ico (CODE:200|SIZE:43)
+ https://certifiedhacker.com/global.asa (CODE:406|SIZE:226)
+ https://certifiedhacker.com/id_rsa (CODE:406|SIZE:226)
=> DIRECTORY: https://certifiedhacker.com/images/
+ https://certifiedhacker.com/index.html (CODE:200|SIZE:13049)
=> DIRECTORY: https://certifiedhacker.com/js/
=> DIRECTORY: https://certifiedhacker.com/mailman/
+ https://certifiedhacker.com/main.mdb (CODE:406|SIZE:226)
=> DIRECTORY: https://certifiedhacker.com/news/
=> DIRECTORY: https://certifiedhacker.com/notifications/
+ https://certifiedhacker.com/php.ini (CODE:403|SIZE:318)
=> DIRECTORY: https://certifiedhacker.com/pipemail/
+ https://certifiedhacker.com/server-info (CODE:406|SIZE:226)
+ https://certifiedhacker.com/web.config (CODE:406|SIZE:226)
+ https://certifiedhacker.com/webmail (CODE:200|SIZE:33950)
=> DIRECTORY: https://certifiedhacker.com/xml/

--- Entering directory: https://certifiedhacker.com/blog/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: https://certifiedhacker.com/cgi-bin/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: https://certifiedhacker.com/cgi-sys/ ---
+ https://certifiedhacker.com/cgi-sys/.bash_history (CODE:406|SIZE:226)
+ https://certifiedhacker.com/cgi-sys/.history (CODE:406|SIZE:226)
+ https://certifiedhacker.com/cgi-sys/.htaccess (CODE:403|SIZE:318)
+ https://certifiedhacker.com/cgi-sys/.htpasswd (CODE:403|SIZE:318)
+ https://certifiedhacker.com/cgi-sys/.sh_history (CODE:406|SIZE:226)

(!) FATAL: Too many errors connecting to host
(Possible cause: OPERATION TIMEOUT)

```

END_TIME: Sat Jul 26 15:31:41 2025

DOWNLOADED: 5760 - FOUND: 23

msf6

nsfconsole

Metasploit tip: The use command supports fuzzy searching to try and select the intended module, e.g. use kerberos/get_ticket or use kerberos forge silver ticket



```

= [ metasploit v6.4.64-dev ]
+ -- [ 2519 exploits - 1296 auxiliary - 431 post ]
+ -- [ 1607 payloads - 49 encoders - 13 nops ]
+ -- [ 9 evasion ]

```

Metasploit Documentation: <https://docs.metasploit.com/>

```

use exploitsfsf > use exploit/unix/webapp/php_cgi_arg_injection
[-] No results from search
[-] Failed to load module: exploit/unix/webapp/php_cgi_arg_injection
msf6 > use exploit/unix/webapp/php_cgi_arg_injection
[-] No results from search
[-] Failed to load module: exploit/unix/webapp/php_cgi_arg_injection
msf6 > use exploit/unix/webapp/php_cgi_arg_injection set RHOSTS certifiedhacker.com set TARGETURI / exploit
[-] No results from search
[-] Failed to load module: exploit/unix/webapp/php_cgi_arg_injection
msf6 >

```

```

(root@kali)~#
# nmap -sV --script vuln certifiedhacker.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-26 15:23 IST
Nmap scan report for certifiedhacker.com (162.241.216.11)
Host is up (0.27s latency).
rDNS record for 162.241.216.11: box533i.bluehost.com
Not shown: 979 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      Pure-FTPd
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
| vulners:
|   CVE-2018-20685 5.3 https://vulners.com/cve/CVE-2018-20685
|   CVE-2018-15919 5.3 https://vulners.com/cve/CVE-2018-15919
|   CVE-2018-15473 5.3 https://vulners.com/cve/CVE-2018-15473
|   CVE-2017-15906 5.3 https://vulners.com/cve/CVE-2017-15906
|   CVE-2016-20012 5.3 https://vulners.com/cve/CVE-2016-20012
|   1337DAY-ID-31730 5.3 https://vulners.com/zdt/1337DAY-ID-31730 *EXPLOIT*
|   SSH_ENUM 5.0 https://vulners.com/canvas/SSH_ENUM *EXPLOIT*
|   PACKETSTORM:150621 5.0 https://vulners.com/packetstorm/PACKETSTORM:150621 *EXPLOIT*
|   EXPLOITPACK:F957D7EBA0CC1E23C3C649B764E13FB0 5.0 https://vulners.com/exploitpack/EXPLOITPACK:F957D7EBA0CC1E23C3C649B764E13FB0 *EXPLOIT*
|   EXPLOITPACK:E80BC5685E3276D648B4D14B75563283 5.0 https://vulners.com/exploitpack/EXPLOITPACK:E80BC5685E3276D648B4D14B75563283 *EXPLOIT*
|   CVE-2025-32728 4.3 https://vulners.com/cve/CVE-2025-32728
|   CVE-2021-36368 3.7 https://vulners.com/cve/CVE-2021-36368
|   PACKETSTORM:151227 0.0 https://vulners.com/packetstorm/PACKETSTORM:151227 *EXPLOIT*
|   PACKETSTORM:140261 0.0 https://vulners.com/packetstorm/PACKETSTORM:140261 *EXPLOIT*
|   1337DAY-ID-30937 0.0 https://vulners.com/zdt/1337DAY-ID-30937 *EXPLOIT*
23/tcp    filtered telnet
25/tcp    filtered snmp
26/tcp    open  snmp      Exin snmpd 4.98.1
| vulners:
|   cpe:/a:exin:exin:4.98.1:
|   CVE-2025-30232 0.1 https://vulners.com/cve/CVE-2025-30232
53/tcp    open  domain    ISC BIND 9.11.4-P2 (RedHat Enterprise Linux 7)
| vulners:
|   cpe:/a:isc:bind:9.11.4-p2:
|   CVE-2021-25216 9.8 https://vulners.com/cve/CVE-2021-25216
|   CVE-2020-8616 8.6 https://vulners.com/cve/CVE-2020-8616
|   CVE-2020-8625 8.1 https://vulners.com/cve/CVE-2020-8625
|   PACKETSTORM:180550 7.5 https://vulners.com/packetstorm/PACKETSTORM:180550 *EXPLOIT*
|   MSF:AUXILIARY-DOS-DNS-BIND_TSIG_BADTIME- 7.5 https://vulners.com/metasploit/MSF:AUXILIARY-DOS-DNS-BIND_TSIG_BADTIME- *EXPLOIT*
|   FBC03933-7A65-52F3-83F4-4B2253A49086 7.5 https://vulners.com/githubexploit/FBC03933-7A65-52F3-83F4-4B2253A49086 *EXPLOIT*
|   CVE-2023-50387 7.5 https://vulners.com/cve/CVE-2023-50387
|   CVE-2023-4408 7.5 https://vulners.com/cve/CVE-2023-4408
|   CVE-2023-3341 7.5 https://vulners.com/cve/CVE-2023-3341
|   CVE-2023-2828 7.5 https://vulners.com/cve/CVE-2023-2828
|   CVE-2022-38178 7.5 https://vulners.com/cve/CVE-2022-38178
|   CVE-2022-38177 7.5 https://vulners.com/cve/CVE-2022-38177
|   CVE-2022-3488 7.5 https://vulners.com/cve/CVE-2022-3488
|   CVE-2021-25215 7.5 https://vulners.com/cve/CVE-2021-25215
|   CVE-2020-8623 7.5 https://vulners.com/cve/CVE-2020-8623
|   CVE-2020-8617 7.5 https://vulners.com/cve/CVE-2020-8617
|   CVE-2018-5744 7.5 https://vulners.com/cve/CVE-2018-5744
|   CVE-2018-5743 7.5 https://vulners.com/cve/CVE-2018-5743
|   CER3668F-E17D-557A-B1B4-C7D0031482C0 7.5 https://vulners.com/githubexploit/CER3668F-E17D-557A-B1B4-C7D0031482C0 *EXPLOIT*

```



```

1337DAY-ID-26792      0.0  https://vulners.com/zdt/1337DAY-ID-26792  *EXPLOIT*
1337DAY-ID-26670      0.0  https://vulners.com/zdt/1337DAY-ID-26670  *EXPLOIT*
1337DAY-ID-22707      0.0  https://vulners.com/zdt/1337DAY-ID-22707  *EXPLOIT*
1337DAY-ID-22375      0.0  https://vulners.com/zdt/1337DAY-ID-22375  *EXPLOIT*
88/tcp open http Apache httpd
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
|_http-dombased-xss: Couldn't find any DOM based XSS.
110/tcp open pop3 Dovecot pop3d
143/tcp open imap Dovecot imapd
443/tcp open ssl/http Apache httpd
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
465/tcp open ssl/smtp Exim smtpd 4.98.1
| vulners:
|_ cpe:/a:exim:exim:4.98.1:
|_ CVE-2025-30232 8.1 https://vulners.com/cve/CVE-2025-30232
587/tcp open smtp Exim smtpd 4.98.1
|_ smtp-vuln-cve2010-4344:
|_ The SMTP server is not Exim: NOT VULNERABLE
| vulners:
|_ cpe:/a:exim:exim:4.98.1:
|_ CVE-2025-30232 8.1 https://vulners.com/cve/CVE-2025-30232
993/tcp open ssl/imap Dovecot imapd
995/tcp open ssl/pop3 Dovecot pop3d
1080/tcp filtered socks
2222/tcp open ssh OpenSSH 7.4 (protocol 2.0)
| vulners:
|_ cpe:/a:openssh:openssh:7.4:
|_ 95499236-C9FE-56A6-9D7D-E943A24B633A 10.0 https://vulners.com/githubexploit/95499236-C9FE-56A6-9D7D-E943A24B633A *EXPLOIT*
|_ 5E696884-D8D6-57FA-BF6E-D9B2219D827A 10.0 https://vulners.com/githubexploit/5E696884-D8D6-57FA-BF6E-D9B2219D827A *EXPLOIT*
|_ 2C119FFA-ECE0-5E14-A4AA-354A2C38071A 10.0 https://vulners.com/githubexploit/2C119FFA-ECE0-5E14-A4AA-354A2C38071A *EXPLOIT*
|_ PACKETSTORM:173661 9.8 https://vulners.com/packetstorm/PACKETSTORM:173661 *EXPLOIT*
|_ F0979183-AE88-53B4-B6CF-3AF0523F3807 9.8 https://vulners.com/githubexploit/F0979183-AE88-53B4-B6CF-3AF0523F3807 *EXPLOIT*
|_ CVE-2023-38408 9.8 https://vulners.com/cve/CVE-2023-38408
|_ 8B190CDB-3EB9-5631-9828-8064A1575823 9.8 https://vulners.com/githubexploit/8B190CDB-3EB9-5631-9828-8064A1575823 *EXPLOIT*
|_ 8FC9C5AB-3968-5F3C-825E-E8D85379A623 9.8 https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8D85379A623 *EXPLOIT*
|_ 8AD01159-548E-546E-AAB7-2DE89F3927EC 9.8 https://vulners.com/githubexploit/8AD01159-548E-546E-AAB7-2DE89F3927EC *EXPLOIT*
|_ 2227729D-6700-5CBF-8930-1EEAFD4B9FF0 9.8 https://vulners.com/githubexploit/2227729D-6700-5CBF-8930-1EEAFD4B9FF0 *EXPLOIT*
|_ 0221525F-07F5-5790-912D-F4B9E2D10587 9.8 https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D10587 *EXPLOIT*

```


- Implement X-Frame-Options, HSTS, and other headers
- Remove sensitive paths from robots.txt
- Disable technology disclosure in headers
- Enable brute-force protection (rate limiting, CAPTCHA, 2FA)

Overall Security Rating: ★ 7.5 / 10